



SPR05_정보시스템 로그 및 백업 관리 절차_Ver1.0



로그 및 백업 현황

<https://docs.google.com/spreadsheets/d/10FFXuezawsuzy3OWNXOf4hLuLmmbqaGV/edit?gid=293779008#gid=293779008>

소관부서 : 정보정보보안팀

버전: Ver 1.0

I. 개요

1. 목적

1. 목적
2. 적용범위
3. 용어 정의
4. 관련근거

II. 정보시스템 로그 관리

1. 로그 관리 기준
2. 로그 유형별 보관 주기

III. 정보시스템 백업 관리

1. 백업관리 기준
2. 주요 백업 대상
3. 백업 복구 절차

I. 개요

1. 목적

이 절차서는 회사의 정보시스템 운영과 관련된 로그 및 백업 데이터를 체계적으로 관리함으로써, 시스템 장애나 보안사고 발생 시 원인 분석과 신속한 복구가 가능하도록 하고, 정보의 기밀성·무결성·가용성을 유지하는 것을 목적으로 한다.

2. 적용범위

본 절차서는 회사가 운영하는 모든 정보시스템(서버, 네트워크, DBMS, 클라우드 서비스 등) 및 이를 관리·운영하는 임직원과 외주 인력을 대상으로 한다.

3. 용어 정의

1. **로그(Log)**: 정보시스템, 응용프로그램, 네트워크 및 보안시스템 등에서 발생하는 접근, 변경, 오류, 이벤트 등의 기록 정보를 말한다.
2. **접속계정 권한 부여 로그**: 시스템 또는 서비스 접근계정의 생성, 변경, 권한 부여·회수 등의 내역을 기록한 로그를 말한다.
3. **접속기록 로그**: 정보시스템(서버, 네트워크, DBMS, 클라우드 등)에 사용자가 접속한 일시, 계정, IP, 수행업무 등의 이력을 기록한 로그를 말한다.
4. **시스템 로그**: 운영체제(OS), 네트워크 장비, 클라우드 플랫폼(EKS 등)의 정상 동작 상태, 오류 및 시스템 이벤트 등을 기록한 로그를 말한다.
5. **실행기록 로그**: 시스템 운영자 또는 응용프로그램이 수행한 명령, 배포, 작업 내역 등의 실행 이력을 기록한 로그를 말한다.
6. **패킷 로그**: 네트워크 구간에서 송·수신되는 데이터 패킷의 흐름, 접근 및 통신 내역을 기록한 로그를 말한다.
7. **백업(Backup)**: 장애, 사고, 재해 등에 대비하여 정보시스템의 데이터를 동일 또는 별도의 저장매체에 복제·저장하는 행위를 말한다.

4. 관련근거

1. 「전자금융감독규정」 제14조의2(전산설비의 안전성 확보)
2. 「개인정보 보호법」 제29조(안전조치 의무)
3. 「신용정보감독규정」 제20조(기술적·물리적·관리적 보안대책)
4. 「정보시스템보안지침」 제16조(로그관리), 제21조(백업 관리)

II. 정보시스템 로그 관리

1. 로그 관리 기준

- 내·외부에 의한 침해시도, 개인정보 유출 시도 및 부정행위 등 이상행위를 분석할 수 있도록 로그를 수집하여야 한다.
- 서버, 응용프로그램, 보안시스템, 네트워크시스템 등 정보시스템에 대한 로그관리 절차를 수립하고 이에 따라 필요한 로그를 생성하여 보관하여야 한다.
- 검토주기에 따라 정보시스템 로그관리 대장에 작성하고 검토하여야 한다.

2. 로그 유형별 보관 주기

로그 유형	보관기간	검토주기	AWS (Cloud Trail)	Server	Server	Server	DBMS	Network	Security	개인정보 처리시스템
				Linux 계열	Windows	EKS	RDS			
접속계정 권한부 여 로그	3년 이상	1개월	IAM log	secure	Secure Event	Audit log(RBAC)	Audit log	계정생성 및 권한 부여 로그	계정생성 및 권한 부여 로그	계정생성 및 권한 부여 로그
접속기록 로그	1년 이상	1개월	IAM log	message	Secure Event	Authenticator/Audit log	Audit log	시스템 접속 로그*	시스템 접속 로그*	시스템 접속 로그*
시스템 로그	6개월 이상(선택)	1개월	Message log	messages	Sys Event	api, controllerManager, scheduler	Error log	시스템 로그	시스템 로그	-
실행기록 로그	6개월 이상(선택)	1개월	EC2 log 등	history, sulog	-	Audit log	general log	-	정책변경 로그	-
패킷 로그	6개월 이상(선택)	1개월	-	-	-	istio access log	-	packet log	-	-

* 시스템 접속 로그* : 접속자 계정(ID), 접속 일시, 접속지 정보(IP 등), 수행업무(조회, 변경, 입력, 삭제, 다운로드 등) 등

III. 정보시스템 백업 관리

1. 백업관리 기준

- 재해 및 재난, 장애, 침해사고 등으로 인한 정보시스템 손상 시 적시에 복구가 가능하도록 백업 대상, 주기, 방법, 절차 등이 포함된 백업 및 복구절차를 수립·이행하여야 한다.
- 중요정보가 저장된 백업매체의 경우 재해, 재난에 대처할 수 있도록 백업매체를 물리적으로 거리가 있는 곳에 소산 보관하고 관리대장으로 소산 이력을 관리하여야 한다.
- 시스템운영자, 시스템개발자 및 개인정보취급자는 검토주기에 따라 백업관리 대장에 작성하고 검토해야 한다.

2. 주요 백업 대상

구분	백업대상	백업 주기	백업방법	보존기간	소산 보관	관리자	비고
OS (시스템 등)	OS 이미지, 시스템 구성 파일 등	월 1회 또는 시스템 변경 시	FULL	-	-	시스템운영자	
데이터베이스	데이터 구성파일, 데이터 파일 등	구성파일 변경 시/월 1회	FULL/INC	-	필수	시스템운영자	
개발 소스	개발소스 파일 등	개발소스 변경 시	FULL	-	필수	시스템개발자	
정보시스템 로그	접속계정 권한부여 로그, 접속기록 로그, 시스템 로그 등	월 1회 또는 실시간(수시)	INC	3년 이상	필수	개인정보취급자	

* INC: 증분백업 / FULL: 전체 백업

3. 백업 복구 절차

- 주요 정보시스템의 경우 IT 재해 복구 측면에서 백업정보의 완전성, 정확성 등을 위해 복구절차를 수립하고 정기적으로 테스트 수행이 필요하다.
- 백업 복구 절차는 각 서비스 단위 환경을 고려하여 시스템운영자가 수립하고 정기적으로 테스트를 수행한다.

▼ 개정 이력

[illegible]